

Comandos essenciais do Nmap

```
pc-security@pc-security-DH8BW01:~$ nmap
Nmap 7.95 ( https://nmap.org )
Usage: nmap [Scan Type(s)] [Options] {target specification}
TARGET SPECIFICATION:
  Can pass hostnames, IP addresses, networks, etc.
  Ex: scanme.nmap.org, microsoft.com/24, 192.168.0.1; 10.0.0-255.1-254
  -iL <inputfilename>: Input from list of hosts/networks
  -iR <num hosts>: Choose random targets
  --exclude <host1[,host2][,host3],...>: Exclude hosts/networks
  --excludefile <exclude_file>: Exclude list from file
HOST DISCOVERY:
  -sL: List Scan - simply list targets to scan
  -sn: Ping Scan - disable port scan
  -Pn: Treat all hosts as online -- skip host discovery
  -PS/PA/PY/PY[portlist]: TCP SYN, TCP ACK, UDP or SCTP discovery to given ports
  -PE/PP/PM: ICMP echo, timestamp, and netmask request discovery probes
  -PO[protocol list]: IP Protocol Ping
  -n/-R: Never do DNS resolution/Always resolve [default: sometimes]
  --dns-servers <serv1[,serv2],...>: Specify custom DNS servers
  --system-dns: Use OS's DNS resolver
  --traceroute: Trace hop path to each host
SCAN TECHNIQUES:
  -sS/sT/sA/sW/sM: TCP SYN/Connect()/ACK/Window/Maimon scans
  -sU: UDP Scan
```

1. Descoberta de hosts (quem está ativo na rede)

`nmap -sn 192.168.0.0/24`

- **-sn (ping scan)**: descobre quais máquinas estão ativas sem escanear portas
- Muito usado no início de qualquer análise

2. Scan padrão (rápido e direto)

`nmap -Pn 192.168.0.XXX`

- Escaneia as **1000 portas mais comuns**
- Mostra quais estão abertas

3. Scan SYN (o mais usado em pentest)

`nmap -sT -sV -Pn 192.168.0.XXX`

- Não completa o handshake TCP

Esse é o “feijão com arroz” de analista de segurança

4. Scan de versão dos serviços

`nmap -sV -Pn 192.168.0.XXX`

- **-sV**: identifica versões de serviços (Apache, SSH, etc.)
- Muito útil para detectar vulnerabilidades

5. Scan do sistema operacional

`sudo nmap -O 192.168.0.XXX`

- **-O**: tenta identificar o sistema operacional
- Usa fingerprint de rede

6. Scan completo (muito usado em auditorias)

`sudo nmap -sS -sV -O 192.168.0.XXX`

Combina:

- portas abertas
- versões
- sistema operacional

7. Scan de todas as portas

`sudo nmap -p- 192.168.0.XXX`

- **-p-**: escaneia **todas as 65535 portas**
- Mais demorado, mas completo

8. Scan de portas específicas

`nmap -p 22,80,443 192.168.0.XXX0`

- Escaneia só portas definidas
- Muito usado para validação rápida

9. Scan UDP (serviços invisíveis no TCP)

`sudo nmap -sU 192.168.0.XX`

- Detecta serviços UDP (DNS, SNMP)
- Mais lento que TCP

10. Evitar ping (host pode bloquear ICMP)

`nmap -Pn 192.168.0.XX`

- **-Pn**: ignora descoberta e assume que o host está ativo
- Essencial em redes protegidas

11. Scan agressivo (tudo em um)

`sudo nmap -A 192.168.0.XXX`

- Inclui:
 - detecção de OS
 - versão
 - scripts
 - traceroute

Faz muito “barulho” (detectável)

12. Scripts NSE (automatização poderosa)

```
nmap --script vuln 192.168.0.XXX
```

- Executa scripts de vulnerabilidade
- Usa o **Nmap Scripting Engine**

Outros exemplos:

```
nmap --script=http-title 192.168.0.XXX
```

```
nmap --script=ftp-anon 192.168.0.XXX
```

13. Scan rápido

```
nmap -F 192.168.0.XXX
```

- Escaneia menos portas
- Muito mais rápido

14. Controle de velocidade (evasão/detecção)

```
nmap -T4 192.168.0.XXX
```

- **-T0 a T5:**
 - T0 = muito lento (stealth)
 - T5 = muito rápido (barulhento)

Uso comum: **T3 ou T4**

15. Saída salva (relatórios)

```
nmap -oN resultado.txt 192.168.0.XXX
```

- **-oN:** salva em formato texto

Outros:

```
-oX resultado.xml
```

```
-oG resultado.grep
```

16. Scan em rede inteira

`nmap 192.168.0.0/24`

- Varre todos os IPs da rede

17. Verificação de firewall

`nmap -sA 192.168.0.XXX`

- **ACK scan**: ajuda a identificar regras de firewall

18. Scan stealth (mais discreto)

`nmap -sN 192.168.0.XXX`

- **NULL scan**
- Pode contornar alguns firewalls

19. Fragmentação de pacotes (evasão)

`nmap -f 192.168.0.XXX`

- Divide pacotes para evitar detecção

20. Descoberta + serviço em uma rede (combo real de SOC)

`sudo nmap -sS -sV -Pn 192.168.0.0/24`

Esse aqui é MUITO usado na prática

Dicas de analista

- Sempre usar sudo quando possível → mais precisão
- Começar com **-sn** antes de escanear tudo
- Usar **-Pn** em redes corporativas (ICMP bloqueado)
- Combinar **-sS** + **-sV** na maioria dos casos
- Usar **--script** para automatizar análise

Combo que todo analista usa no dia a dia

Se tivesse que resumir em 3 comandos essenciais:

```
nmap -sn rede/24
```

```
sudo nmap -sS -sV alvo
```

```
sudo nmap -A alvo
```